Open-Core Licensing, Legal & Governance Manual

Intern Management System (IMS) — Commercial & Open-Source Legal Framework Doc Ref: IMS-GOV-01

1. Dual-Licensing Strategy & Repository Boundaries

To drive rapid bottom-up adoption among mid-market engineering leads while preserving high-margin enterprise monetization, the Intern Management System (IMS) utilizes a strict **Single-Repository Open-Core** licensing structure. All community workflow components reside under a permissive open-source license, while enterprise security, identity governance, and compliance modules are isolated inside the top-level `ee/` directory under a commercial license.

Repository Path	Governing License	Permitted Rights	Commercial & Legal Boundary
`cmd/`, `internal/`, `ui/`, `db/`	**MIT License** (Permissive Open-Source)	Free use, modification, self-hosting, and private forking.	Includes Kanban state machine, append-only ledger, threshold nudges, and 30/60/90-day evaluations.
`ee/auth/`, `ee/rbac/`	**IMS Enterprise EULA** (Proprietary)	Source-available for security inspection; execution requires active license key.	Gates SAML 2.0, OIDC, SCIM 2.0 automated user provisioning, and Policy-Based Access Control (PBAC).
`ee/audit/`, `ee/license/`	**IMS Enterprise EULA** (Proprietary)	Zero modification or redistribution rights; tamper-protected.	Gates SIEM log streaming (Datadog/Splunk) and the RS256 cryptographic JWT verification engine.
`docs/`, `deploy/`	**CC-BY-4.0 / MIT**	Public distribution with attribution.	Contains Docker Compose orchestration files, SQLc configuration, and architecture decision records.

2. Contributor License Agreement (CLA) Mandate

Relying solely on a Developer Certificate of Origin (DCO) is insufficient for an open-core business model. Because the vendor compiles community contributions from `internal/` and `ui/` directly into the proprietary Enterprise Edition binary, every external contributor must execute an automated **Individual or Corporate Contributor License Agreement (CLA)** via GitHub PR bot prior to merge. The CLA grants the project owner an irrevocable, perpetual, worldwide, royalty-free sublicense right to distribute contributed code under both the MIT License and the commercial Enterprise EULA.

> **Mandatory Anti-Circumvention Clause (Enterprise EULA §4.2):** Any modification of the source code within `ee/license/`, removal of Go build constraints (`//go:build ee`), or replacement of the embedded RS256 public key to bypass seat limits or expiration checks constitutes an immediate breach of contract and willful copyright infringement.

3. Cryptographic Offline License Enforcement (RS256)

Enterprise financial institutions, healthcare networks, and defense-adjacent tech shops frequently deploy internal tooling inside air-gapped VPCs with strict outbound firewall rules. Calling an external licensing API ("phoning home") is an immediate procurement blocker. Instead, the IMS enforces commercial entitlements completely offline using **Asymmetric RSA-2048 (RS256) JSON Web Tokens**.

When an enterprise purchases a subscription, the vendor's isolated signing server generates a signed license token containing the customer's canonical domain, maximum active intern seats, enabled modules, and expiration timestamp. The self-hosted Go binary verifies the signature at boot and on a 6-hour Asynq tick using a hardcoded public key compiled into the binary.

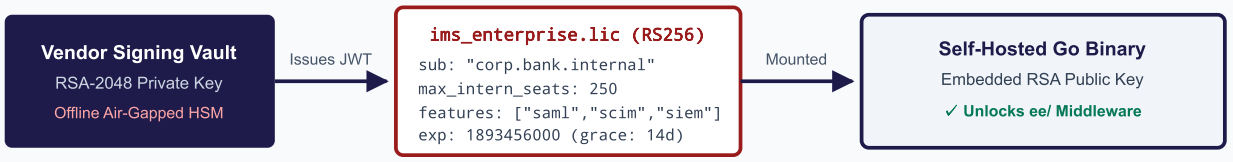


Figure 1: Air-gapped cryptographic verification pipeline requiring zero outbound internet connectivity from the customer environment.

4. Required Commercial EULA Provisions

- **Instance Fingerprinting & Domain Binding:** The license token binds to the configured `APP_DOMAIN` and PostgreSQL cluster UUID. Deploying a single token across multiple isolated production clusters triggers a read-only compliance banner.
- **Seat Quota Definition:** Only active users assigned the `INTERN` role within an open cohort count toward the licensed seat limit. Mentors, engineering leads, and HR administrators are provisioned at zero seat cost to encourage organization-wide adoption.
- **Grace Period & Fail-Safe Behavior:** Upon token expiration, the system enters a 14-day warning state. If unrenewed after 14 days, SAML/SCIM logins fall back to admin recovery mode, but existing HR evaluation records remain exportable so customers are never held hostage from their compliance data.

5. HR Personnel Data Privacy & GDPR Compliance

Because the IMS captures granular performance friction—including task bounce-backs, time-in-state overruns, and mentor-tagged `KNOWLEDGE_GAP` or `CARELESS_ERROR` justifications—the database legally constitutes an **Automated Employee Evaluation & Personnel File System**. Under GDPR Article 5(1)(e) (Storage Limitation) and regional labor laws, organizations cannot retain identifiable intern failure logs indefinitely without explicit legal justification.

To make the platform enterprise-ready for European and regulated markets, the database implements a split retention architecture that separates human identity from mathematical workflow telemetry.

1. Automated PII Cryptographic Scrubbing

When a cohort retention window expires (configurable from 1 to 6 years post-offboarding), an Asynq job executes a GDPR erasure transaction: `intern_id` references on `tasks` and `intercept_events` are replaced with a salted one-way hash, and free-text mentor notes are purged while preserving raw column-transition durations for aggregate department benchmarks.

2. Anti-Profiling Safeguard (GDPR Art. 22)

GDPR prohibits solely automated decisions that produce legal or employment effects. The IMS legally positions its metrics as *Decision-Support Evidence*: the system never auto-rejects an intern for a return offer; a human mentor must explicitly review the dossier and sign the final recommendation toggle.

3. Strict Role Isolation Matrix

Interns have full visibility into their own Kanban board and 30/60/90-day rubric scores, preventing "secret surveillance" claims. However, peer interns cannot view another intern's revision counts or intercept justifications, enforcing strict personnel confidentiality.

4. Third-Party Stack License Cleanliness

Every dependency in the stack uses permissive, non-copyleft licenses: **Go** (BSD-3-Clause), **PostgreSQL** (PostgreSQL License), **SQLc** (MIT), **SvelteKit** (MIT), and **Asynq / Redis client** (MIT/BSD). This guarantees zero viral GPL contamination of the proprietary `ee/` binary.

6. CI/CD Dependency License Gate

> **Automated Build Enforcement:** The repository's GitHub Actions pipeline must run `go-licenses check ./...` and `license-checker` on every pull request. Any package introducing a strongly reciprocal copyleft license (**GPL-2.0, GPL-3.0, or AGPL-3.0**) fails the build immediately, ensuring the compiled binary can always be distributed under commercial enterprise terms without legal encumbrance.